

NIST Cybersecurity Framework 2.0 — Compliance Report

Cisco Secure Workload | Govern, Identify, Protect, Detect, Respond,
Recover

Cisco Secure Workload — Compliance Mapping Series

Version 1.0 (draft — pending SME review)

Table of Contents

Cisco Secure Workload — NIST CSF 2.0 Compliance Mapping

How to read this report

This report describes how Cisco Secure Workload (CSW) supports an organisation’s posture against the **NIST Cybersecurity Framework 2.0** (released February 2024). CSF 2.0 is not a control catalogue — it’s an outcomes framework that **wraps** control catalogues like NIST 800-53, ISO 27001, CIS Controls, and others through Informative References. The right way to read this report is as the “where does CSW evidence land in the CSF 2.0 narrative” view.

What changed in CSF 2.0. A sixth Function — **Govern (GV)** — was added above Identify, Protect, Detect, Respond, Recover. Govern formalises expectations around organisational context, risk strategy, roles and responsibilities, policy, oversight, and cybersecurity supply chain risk management. Several Categories and Subcategories within the existing five Functions were reorganised and refined.

Companion document. The accompanying *CSF 2.0 Reference Design* walks through CSW deployment per Profile / Tier, and the Subcategory-by-Subcategory implementation steps. Read this report for the audit-narrative view; read the reference design for the deployment view.

How to read the Coverage column

Direct means Secure Workload produces the primary evidence artifact for that row — segmentation, policy, flow and process telemetry, inventory, vulnerability and reachability, or forensic reconstruction. Direct is still evidence, not an attestation.

Supporting means Secure Workload contributes an input that feeds or complements another control, tool, or process — detection input only, reconciled against an external register, or one log source among several.

Evidence Required means Secure Workload has no record for that row. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

Every report in this set now uses the same three coverage words — Direct, Supporting, and Evidence Required. Coverage describes what evidence Secure Workload produces; it never means the control is passed.

1. Executive Summary

CSF 2.0 organises cybersecurity outcomes across six Functions, 22 Categories, and 106 Subcategories. CSW is the workload-tier evidence engine for the technical Subcategories under Identify (asset management, risk assessment), Protect (platform security, infrastructure resilience), Detect (continuous monitoring, adverse event analysis), and Respond (analysis, mitigation). Govern and Recover are organisational/process Functions where CSW supplies inputs but is not the primary control.

What CSW changes for a CSF 2.0 programme:

- **GV.OV / GV.SC — Oversight and Supply Chain.** Standing quarterly evidence pack to the management body covering the six CSF Functions with technical detail (workload inventory drift, vulnerability backlog, segmentation diff, detection trends, incident summary, vendor-egress drift). Governance gets ground- truth, not green-yellow-red dashboards.
- **ID.AM / ID.RA — Asset Management and Risk Assessment.** Continuous workload inventory + ADM dependency graph + per- workload CVE inventory with reachability-aware prioritisation.
- **PR.IR / PR.PS — Infrastructure Resilience and Platform Security.** Workload-level deny-by-default segmentation enforcement (PR.IR-01); daily configuration baseline with drift detection (PR.PS-01); software lifecycle including vendor-EOL tagging (PR.PS-02); SIEM forwarding (PR.PS-04).
- **DE.CM / DE.AE — Continuous Monitoring and Adverse Event Analysis.** The densest CSW alignment in CSF. Per-workload process + flow telemetry; behavioural rules; conversation-graph anomaly detection; SIEM correlation.
- **RS.AN / RS.MI — Incident Analysis and Mitigation.** Six- artefact reconstruction bundle for every declared incident; quarantine policy templates pre-built per scope.

What CSW does not change. CSW does not address physical/ environmental Subcategories (PR. IR- 02, DE . CM- 02), backup/ recovery Subcategories (RC . RP - 02/03), or training/HR-style Subcategories. Identity is upstream (PR.AA is supporting; CSW enforces workload-side outcomes of upstream identity decisions).

2. Compliance Posture Summary

Function	Coverage	CSW contribution
Govern (GV)	Supporting	Quarterly evidence pack; vendor-egress observation

Function	Coverage	CSW contribution
		feeding GV.SC
Identify (ID)	Direct	ID.AM: continuous workload + flow + software inventory. ID.RA: continuous CVE + reachability + drift evidence
Protect (PR)	Direct	PR.IR: segmentation enforcement. PR.PS: baseline + drift + SIEM + behavioural rules. PR.AA / PR.DS: supporting (workload-side enforcement of upstream identity, plaintext DENY)
Detect (DE)	Direct	DE.CM: workload telemetry + behavioural rules + anomaly detection. DE.AE: forensic timeline + SIEM correlation + threat intel
Respond (RS)	Direct	RS.MA / RS.AN: six-artefact dossier + severity routing + magnitude estimate. RS.MI: quarantine policy templates
Recover (RC)	Supporting	Pre-incident segmentation export available for re-application; post-recovery diff = evidence of new normal

Posture takeaway. Direct on Identify, Protect, Detect, Respond (the technical core of the framework). Supporting on Govern (where CSW supplies evidence the management body uses) and on Recover (where CSW supplies pre/post-incident state diffs but is not the recovery executor itself). This is consistent with CSW’s positioning as a workload-protection platform: it is the evidence engine for the operational Functions and the input source for the governance Function.

3. Mapping Table — CSF 2.0 Subcategory → CSW Capability → Evidence Artefact

Subcategory	Topic	CSW capability	Evidence artefact (audit-ready)
GV.OV-01/02/03	Oversight	Quarterly evidence pack	Standing quarterly pack with management-body

Subcategory	Topic	CSW capability	Evidence artefact (audit-ready)
			sign-off
GV.SC-04	Suppliers known and prioritised	Vendor-egress inventory per scope	Vendor-egress CSV per scope
GV.SC-07	Risks of suppliers monitored	Vendor-egress drift report	Drift report tied to contract register
GV.SC-09	Supply chain security practices integrated	Egress allowlist + reconciliation	Allowlist policy export + delta report
GV.SC-10	Supply chain plans address EOL	Software inventory with vendor-EOL flags	EOL software register
ID.AM-01	Hardware inventory	Continuous workload + cloud asset metadata	Inventory CSV per scope
ID.AM-02	Software inventory	Per-workload package + service inventory	Package inventory dated to cadence
ID.AM-03	Network communication & flow representations	ADM dependency graph; observed flow inventory	ADM export + observed-flow CSV
ID.AM-04	Supplier service inventory	Vendor-egress observation + reconciliation	Vendor-egress CSV + register reconciliation
ID.AM-05	Asset prioritisation	<code>crit_band</code> labels drive scope-based prioritisation	Scope-tagged inventory CSV
ID.AM-07	Data inventory metadata	Workload labels (<code>data_class</code>)	Data-class-labelled inventory CSV
ID.AM-08	Asset lifecycle	Vendor-EOL flags in software inventory	EOL register
ID.RA-01	Vulnerabilities identified	Continuous CVE inventory per workload	CVE list per workload
ID.RA-02	Cyber threat intelligence received	CSW threat-intel feeds enrich CVE prioritisation	Threat-intel-enriched CVE export
ID.RA-03	Threats identified and recorded	Behavioural detection rule catalogue	Rule catalogue with last-modified dates
ID.RA-05	Risk inherent + response	Reachability-aware CVE prioritisation	CVE list with reachability + EPSS

Subcategory	Topic	CSW capability	Evidence artefact (audit-ready)
	prioritisation		scoring
ID.RA-06	Risk responses chosen + tracked	CVE backlog + remediation tracking	Patch SLA compliance trend + compensating-control register
ID.RA-07	Changes & exceptions managed	Configuration drift report + change-ticket attribution	Daily diff log with ticket linkage
PR.AA-01/05	Identity & access enforcement	Workload-side enforcement (identity upstream)	Policy export with rule provenance
PR.DS-02	Data-in-transit protected	Plaintext-protocol DENY enforcement	Plaintext-flow alert log + DENY policy
PR.IR-01	Networks protected from unauthorised access	Workload-level deny-by-default segmentation	Workspace export per scope
PR.IR-03	Resilience requirements achieved	Quarantine policy + segmentation under change control	Quarantine policy templates + change history
PR.PS-01	Configuration management	Daily baseline + drift detection	Baseline export + diff log
PR.PS-02	Software maintained	Per-workload software inventory + EOL tagging	Software inventory + EOL register
PR.PS-04	Log records generated	Per-flow + per-process telemetry to SIEM	SIEM forwarding configuration
PR.PS-05	Unauthorised software prevented	Behavioural rules + (IG3) allow-list block	Behavioural rule catalogue + alert log
PR.PS-06	Secure software development	CVE inventory feeds SDLC	CVE feed + reachability for triage
DE.CM-01	Networks monitored	CSW flow telemetry + behavioural rules + SIEM	Flow log retention + sample retrieval
DE.CM-03	Personnel activity monitored	Process telemetry + identity-aware policy	Process event sample with attribution
DE.CM-06	External service provider activities monitored	Vendor-egress observation + drift alerting	Vendor-egress alert log
DE.CM-09	Computing	Per-workload process	Per-workload

Subcategory	Topic	CSW capability	Evidence artefact (audit-ready)
	hardware/software/runtime monitored	+ package + flow telemetry	telemetry retention configuration
DE.AE-02	Adverse events analysed	Forensic flow + process timeline reconstruction	Sample reconstruction per quarter
DE.AE-03	Information correlated from multiple sources	CSW telemetry forwarded to SIEM	SIEM forwarding + correlation rules
DE.AE-04	Impact and scope understood	Reachability + crit_band labels inform impact	Impact report per significant event
DE.AE-06	Information provided to authorised staff/tools	SIEM forwarding + alert routing per scope	Alert routing configuration
DE.AE-07	Threat intel + contextual info integrated	Threat-intel-enriched detections	Enrichment configuration
DE.AE-08	Incidents declared per criteria	Severity-based alert routing → IR ticket	Severity threshold configuration + sample ticket
RS.MA-01 to 05	Incident management	Six-artefact dossier + severity routing	Sample dossier + severity routing config
RS.AN-03	Analysis to establish root cause	Process + flow timeline reconstruction	Sample analysis output
RS.AN-06	Investigation actions recorded	CSW retains queries and exports; SIEM hashing	Query audit log + chain-of-custody documentation
RS.AN-07	Incident data and metadata collected	Six-artefact dossier with timestamped exports	Sample dossier
RS.AN-08	Magnitude estimated and validated	Reachability + scope membership inform magnitude	Magnitude analysis per significant incident
RS.MI-01	Incidents contained	Quarantine policy applied per workload	Quarantine event log
RS.MI-02	Incidents eradicated	Compensating-control register; sustained policy	Compensating-control register + post-eradication

Subcategory	Topic	CSW capability	Evidence artefact (audit-ready)
			policy
RC.RP-04	Post-incident operational norms	Post-recovery segmentation diff	Diff report per recovered incident
RC.RP-05	Restored asset integrity verified	CSW re-baseline after recovery	Post-recovery baseline export
RC.RP-06	End of recovery declared	Final dossier inclusion of post-recovery diff	Closed-incident dossier with diff

4. Out-of-Scope and Complementary Controls

CSW does **not** address the following Subcategories; reference the noted complementary controls.

Subcategory	Owner	Complementary control
GV.RR — Roles, Responsibilities, Authorities	Security leadership	Programme charter, RACI, escalation paths
GV.PO — Policy	Security leadership	Policy library
PR.AT — Awareness and Training	HR + Security training	LMS + phishing simulation
PR.IR-02	Facilities	Physical / environmental controls
PR.DS-01	Identity / Crypto SME	Encryption-at-rest configuration
DE.CM-02	Facilities + Physical Security	Physical environment monitoring
RC.RP-02 / RC.RP-03	Backup / DR team	Backup product + integrity testing
RC.CO — Recovery Communications	Communications + IR leadership	Stakeholder communications process

CSW's role in a complete CSF 2.0 programme is the workload-tier evidence engine for the technical Functions (ID, PR, DE, RS) and the input source for the governance Function (GV) and the operational evidence layer for Recover (RC). Identity, physical, backup, training, and crypto-at-rest are explicitly upstream.

5. Suggested Next Steps

For organisations adopting or maturing CSF 2.0 posture with CSW:

1. **Confirm your Profile.** CSF 2.0 expects Current Profile, Target Profile, and progress measurement between them. Get security leadership to sign off the Profile before scoping CSW labels and scopes — CSW evidence aggregates per Subcategory and per scope, so the Profile structure determines the report structure.
 2. **Pilot on ID.AM, PR.IR, DE.CM.** These are the densest CSW alignment in CSF and produce the fastest visible wins. Inventory and ADM are the foundation; PR.IR is where the segmentation work lives; DE.CM is where the daily detection work lives.
 3. **Build the GV evidence pack early.** CSF 2.0's new Govern Function expects management-body engagement. The quarterly evidence pack (workload inventory drift, vulnerability backlog, segmentation diff, detection trends, incident summary, vendor-egress drift) is the artefact governance asks for once and reuses every cycle.
 4. **Wire CSW telemetry into the SIEM you already have.** CSF DE . CM and DE . AE rely on correlation across data sources; CSW is one source among many. The uplift comes from richer workload-tier data, not from replacing the SIEM.
 5. **Standardise the RS.AN-07 incident dossier template.** The six-artefact bundle is the artefact RS subcategories converge on; build it once and reuse.
 6. **Plan SME review.** This document is a v1 mapping. Before being relied upon in a formal compliance engagement, route to a CSF specialist for currency (CSF Quick-Start Guides and Implementation Examples evolve) and to a current Cisco Secure Workload SE for product-capability accuracy.
-

6. Disclaimer

This report and its companion reference design describe how Cisco Secure Workload capabilities can support a NIST Cybersecurity Framework 2.0 programme. They are **not** legal or compliance advice and do not constitute a finding of compliance.

Specifically:

- NIST publishes the authoritative CSF 2.0 text and Subcategory list at <https://www.nist.gov/cyberframework>. Always validate against the **current effective version** of CSF, including any released Quick-Start Guides, Profiles, Implementation Examples, and Informative References mappings.
- CSF 2.0 is an outcomes framework and does not prescribe specific controls. Mapping a CSW capability to a Subcategory does not by itself satisfy the Subcategory — the organisation's Profile, Tier, and accompanying control set determine the depth of work expected.
- CSW does not address physical/environmental Subcategories, backup/ recovery Subcategories, or training/HR-style Subcategories. Reference the appropriate parts of your programme for those.

This document should receive subject-matter-expert review for both CSF 2.0 currency and current Cisco product capability before being used in a customer engagement.